

****Supervision of Lolland Municipality****

****Date: 22-12-2023****

****Decision****

****Public Authorities****

****Serious Criticism****

****Order****

****Supervision / Self-Management Case****

****Processing Security****

****Fundamental Principles****

****Risk Assessment and Impact Analysis****

The Data Protection Agency has made a decision in five supervision cases regarding the processing security in AULA. The Data Protection Agency found reason to issue an order for the preparation of impact analyses in two of the cases. Furthermore, the supervision has expressed criticism and serious criticism in the cases.

****Journal Number: 2023-423-0007.****

****Summary****

The Data Protection Agency initiated supervision in the autumn of 2021 concerning the processing of personal data in the IT system AULA by a total of six selected municipalities. The supervisions focused on compliance with the data protection regulation's rules on processing security and impact analysis. "When schools/childcare institutions and parents communicate via AULA, sensitive and confidential information about children is often involved. It is therefore important that municipalities take good care of the information in AULA. According to the data protection regulation, children have a right to special protection," says Signe Vestergård, special consultant at the Data Protection Agency.

The Data Protection Agency has now made decisions in all cases except one, as this case contains some additional elements.

The supervisions are a continuation of the Data Protection Agency's previous supervision of Kombit A/S (hereinafter KOMBIT) in December 2019. During the relevant supervision visit, the Data Protection Agency found that KOMBIT could not be regarded as the data controller for AULA under Article 4, No. 7 of the data protection regulation. At the supervision meeting, the Data Protection Agency informed KOMBIT that KOMBIT should ensure that all municipalities were informed of their data responsibilities and that KOMBIT should transfer all necessary materials and information to the municipalities in this regard.

The Data Protection Agency finds that the supervision cases raise some general data protection legal issues across the municipalities, which can advantageously be handled collectively rather than separately at the individual municipalities. Therefore, the Data Protection Agency has chosen to inform the Association of Danish Municipalities (KL), the Agency for IT and Learning, and Kombit A/S (hereinafter KOMBIT) about the agency's decisions in these cases. At the same time, the Data Protection Agency has formulated some recommendations for further work on processing security in AULA.

Furthermore, the Data Protection Agency will provide the same recommendations in a letter to all municipalities in the country, where the agency will also inform about the decisions. The purpose of the communication to the municipalities is to encourage them to consider whether the material gives rise to (further) assessments, etc., or to ensure the implementation of additional security measures concerning their processing of personal data in AULA.

****Impact Analysis****

Although the five municipalities use the same technical solution (AULA) for the same processing activities, they have had a markedly different approach to the issue of impact analyses.

All five municipalities have received criticism or serious criticism in the part of the cases concerning impact analysis. Two of the municipalities have received serious criticism for not having prepared an impact analysis. The Data Protection Agency has furthermore issued these two municipalities an order to prepare an impact analysis within three months.

The other three municipalities have prepared impact analyses. The Data Protection Agency has reviewed them and assessed that none of them meet all the minimum requirements for an impact analysis.

In addition, the Data Protection Agency has examined the timing of the preparation of the impact analyses and taken into account that there has been uncertainty regarding the data responsibility for the processing of personal data in AULA. The municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data and the responsibility for conducting risk assessments and impact analyses lay with KOMBIT. However, the Data Protection Agency concluded during the supervision visit to KOMBIT in December 2019 that KOMBIT cannot be considered the data controller.

All three municipalities prepared the impact analyses only long after clarity regarding the data responsibility for the processing of personal data in AULA had been established. Two of the municipalities even prepared the impact analyses only after the supervision had requested the material in connection with the initiation of the supervision, which is why the Data Protection Agency has expressed serious criticism towards these two municipalities. The Data Protection Agency has expressed criticism towards the third municipality.

****Risk Assessment****

All five municipalities have also received criticism or serious criticism concerning the part of the cases that deal with the municipalities' risk assessment. The criticism relates to the documentation requirement to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses to the individuals concerned, ensuring an appropriate level of security. Furthermore, the criticism concerns the lack of identification and implementation of relevant measures to ensure an appropriate level of security.

The Data Protection Agency has expressed serious criticism of two of the municipalities for not having submitted actual risk assessments. One municipality stated in January 2023 that they had not yet completed the initial work of identifying relevant measures that could be implemented to ensure... to reduce the identified high risks associated with the processing of personal data in AULA. The second municipality referred to a number of appendices as documentation for the mitigating measures the municipality had taken to reduce the risk for the registered individuals. The other three municipalities have submitted risk assessments. However, the Data Protection Agency has criticized these municipalities for not sufficiently demonstrating that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The municipalities have responded differently to the material. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have based their descriptions of the measures they have implemented to reduce these risks on it. One municipality states that they have reviewed the material from KOMBIT but concluded that it could not immediately be used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they have identified are assessed to pose a lower risk than what is indicated in KOMBIT's material—however, without sufficiently documenting the basis for this assessment.

****Risk of Misdelivery in AULA****

The Data Protection Agency has found that a large portion of the reports of breaches of personal data security in AULA, which the agency receives, concern the misdelivery of personal data to one or more incorrect recipients in AULA. This is also a risk that several municipalities have identified in their risk assessments. Several of the municipalities have implemented organizational measures aimed at informing users about this risk when sending messages via AULA. Additionally, one of the municipalities has also implemented a change request in AULA that allows for the deletion and editing of sent content in messages.

Despite these measures, the Data Protection Agency continues to receive a number of reports of breaches from the municipalities concerning misdelivery in AULA. It is generally the Data Protection

Agency's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of misdelivery. They should also explore options for designing the messaging function in a way that minimizes such risk.

In a letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has recommended that KOMBIT, together with the responsible municipalities, conduct such an investigation. This recommendation will also be reiterated in a letter to all municipalities in the country.

****Joint Impact Assessment and Code of Conduct****

It is the Data Protection Agency's view that the municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA. This is based on the fact that the municipalities use the same type of system for the same processing activities of the same type of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier.

In the letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has therefore encouraged consideration across municipalities, and possibly in collaboration with KL and KOMBIT, to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Agency has also recommended that KL, in collaboration with the municipalities and possibly KOMBIT, consider the possibility of developing a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. The Data Protection Agency has noted that this consideration may also be relevant for other processing activities in the municipalities, where they use the same system for the same processing activities of the same types of personal data, which involve similar high risks.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures to be followed for a specific processing activity. A code of conduct would therefore be a useful tool to help comply with data protection rules for the authorities that have subscribed to the code. Although it facilitates compliance with the rules, it does not exempt the individual data controller from the obligations and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processes—for example, by using a system for other purposes.

"It is a significant and resource-intensive task for individual municipalities to conduct risk assessments and impact assessments that ensure the appropriate security measures. But it is necessary. AULA is a tool used in all municipalities for the same processing activities of the same type of personal data. We therefore encourage the municipalities—possibly in collaboration with KL and KOMBIT—to come together and ensure that citizens' information in AULA is sufficiently protected," says Signe Vestergård, special consultant at the Data Protection Agency.

1. **Written Supervision of Lolland Municipality Regarding the IT System AULA**

Lolland Municipality is among the six municipalities that...
compliance with other provisions of the data protection regulation.

4. Background

The Danish Data Protection Agency (Datatilsynet) selected Lolland Municipality for supervision in the autumn of 2021 in accordance with the General Data Protection Regulation (GDPR)[1] and the Data Protection Act[2]. The supervision conducted by Datatilsynet is a written oversight with a particular focus on the technical and organizational security measures that have been observed to meet the requirement for an appropriate level of security for the processing activities in the IT system AULA. This supervision is a continuation of Datatilsynet's previous oversight of Kombit A/S (hereinafter referred to as KOMBIT) in December 2019, where the supervision during a site visit could ascertain that KOMBIT is not to be regarded as a data controller for AULA under Article 4, No. 7 of the GDPR.

Therefore, Datatilsynet informed KOMBIT that KOMBIT must ensure that all municipalities are informed of their data responsibilities and that KOMBIT transfers all necessary materials and information to the municipalities in this regard. Datatilsynet expects that KOMBIT informed the municipalities of this immediately after the site visit in December 2019.

2. Decision

After a comprehensive assessment of Lolland Municipality's statements and the submitted materials, Datatilsynet finds that Lolland Municipality has not ensured that appropriate measures have been implemented to protect the data subjects against the identified risks. In this context, Datatilsynet has noted that Lolland Municipality indicated that as of January 2023, they had not yet completed the preliminary work to identify relevant measures that could be implemented to reduce the identified high risks associated with the processing of personal data in AULA. On this basis, Datatilsynet finds grounds to express serious criticism that Lolland Municipality's processing of personal data has not occurred in accordance with Article 5, paragraph 1, letter f, and Article 32, paragraph 1 of the GDPR.

Furthermore, Datatilsynet assesses that Lolland Municipality has not conducted a comprehensive impact assessment, pursuant to Article 35, paragraph 1 of the GDPR, as the documentation submitted, which Lolland Municipality referred to in relation to the supervisory questions about the impact assessment, does not meet the minimum requirements set forth in Article 35, paragraph 7 of the regulation. In this context, Datatilsynet assesses that the submitted material does not constitute an impact assessment, and therefore Lolland Municipality has not prepared an impact assessment for the processing of personal data in AULA. Datatilsynet has particularly emphasized that Lolland Municipality does not appear to have worked with and attempted to mitigate the risks that the processing of personal data in AULA entails.

On this basis, Datatilsynet further finds grounds to express serious criticism that Lolland Municipality's processing of personal data has not occurred in accordance with Article 35, paragraph 1 of the GDPR. Datatilsynet finds grounds to issue an order to Lolland Municipality to conduct an impact assessment regarding data protection for the municipality's processing of personal data in AULA in accordance with Article 35 of the GDPR. The order is issued pursuant to Article 58, paragraph 2, letter d of the GDPR. The deadline for compliance with the order is March 22, 2024. Datatilsynet requests to receive confirmation by the same date that the order has been complied with. According to Section 41, paragraph 2, No. 5 of the Data Protection Act, it is punishable to fail to comply with an order issued by Datatilsynet pursuant to Article 58, paragraph 2 of the GDPR. According to Section 41, paragraph 6, second sentence of the Act, public authorities may also be penalized.

Datatilsynet notes that it follows from Article 36, paragraph 1 of the GDPR that if the impact assessment regarding data protection indicates that the processing will lead to high risk in the absence of measures taken by Lolland Municipality to mitigate the risk, Lolland Municipality must consult Datatilsynet. Lolland Municipality must therefore consult Datatilsynet if, in connection with the preparation of the impact assessment, Lolland Municipality assesses that they cannot adequately mitigate the identified risks, as the residual risks remain high.

3. Case Presentation

Datatilsynet notified Lolland Municipality of the supervision by letter dated October 15, 2021. In this connection, Datatilsynet requested the municipality to submit the following:

- The risk assessments that form the basis for the assessment of what security is deemed appropriate for the processing of information about natural persons in "AULA," as well as a description of the general security models in the application.
- To the extent that impact assessments have been prepared, copies of all versions of these.
- A review of considerations regarding the use of Article 25 of the GDPR in connection with the procurement and development of "AULA."
- A review of authorization and access control models.

Lolland Municipality submitted a statement regarding the case along with a number of attachments on November 6, 2021. Based on the statements from the six selected municipalities, Datatilsynet has

chosen to limit the focus of the supervision to questions regarding risk assessment and impact assessment. It should be emphasized in this context that Datatilsynet has not addressed whether Lolland Municipality's processing of personal data in AULA is in compliance with other provisions of the data protection regulation.

****Compliance with the Data Protection Regulation's Article 25 on Data Protection by Design and Default Settings, or whether the municipality's authorization and access management models comply with the Data Protection Regulation's Article 32.****

The Data Protection Authority has subsequently, by letter dated December 6, 2022, posed a series of clarifying questions to Lolland Municipality regarding the municipality's responses concerning risk assessment and impact analysis. Lolland Municipality responded to these questions on January 9, 2023.

****3.1. General Information on the Decision and Development of AULA****

The Danish Association of Municipalities (hereinafter KL) states on their website that the municipal procurement of AULA is part of the User Portal Initiative, which is a political initiative from 2013.[3] It further states that AULA aims to support communication and thereby collaboration regarding children's learning and well-being in a secure and user-friendly manner. KL also informs that all 98 municipalities in Denmark jointly participated in a common tender for a collaboration platform – the later AULA – for the school sector in 2016. Furthermore, it is stated on KL's website that AULA was put out to tender by the municipalities' IT community, KOMBIT A/S (hereinafter KOMBIT), at the beginning of 2017, and the choice fell on the supplier Netcompany – IT and Business Consulting, which has since developed AULA in collaboration with the companies Frog, EduLab, and Advice. KOMBIT provides information about AULA on the website aulainfo.dk. It is noted that the majority of public schools began using AULA in 2019 and daycare facilities in the winter of 2020/2021.[4] The Data Protection Authority understands that individual municipalities are independently responsible for their processing of personal data in AULA, and that KOMBIT, which is the municipalities' data processor, has entered into a data processing agreement with Netcompany, which thus acts as a sub-processor.[5]

****3.2. Lolland Municipality's Comments****

****3.2.1. Risk Assessment****

Lolland Municipality has stated that they have not prepared independent risk assessments. In this context, Lolland Municipality has indicated that in their work with impact analyses for AULA, they have utilized KOMBIT's specific risk assessments of AULA for selected modules. Lolland Municipality has attached, among other things, 10 Excel sheets titled "Impact Assessment" for 10 different modules in AULA, which were prepared by KOMBIT. The Excel sheets contain a threat catalog, an assessment of the likelihood of various incidents occurring and the consequences for the data subjects, as well as a summary of the overall risk for the data subjects. The material also includes basic data with project name, name of data process (e.g., communication and collaboration in public schools), and the purpose of the data process concerning the various modules in AULA. According to Lolland Municipality, the relevant modules were selected based on an assessment of whether information is processed that, due to the nature, scope, context, and purpose of the information, is likely to involve a high risk to the rights and freedoms of natural persons. In this context, Lolland Municipality notes that this reflects a risk-based approach to the work with personal data security. Based on a random sample review, the Data Protection Authority has found that the attached material from KOMBIT generally establishes that a number of processing activities carried out in AULA involve a high risk for the data subjects. Furthermore, it appears from the material that it is expected/likely that a number of scenarios will occur that involve consequences categorized as "devastating" or "very serious." For example, it appears from KOMBIT's risk assessment for the messaging module in AULA that they have identified 10 threats, three of which are deemed most likely. The three threats are marked in red, and the Data Protection Authority understands from the material that KOMBIT assesses these as high risks. One of the threats concerns user behavior that leads to mishandling of personal data in the system, carried out by an authorized user through inadvertent disclosure of personal data in the application. The

consequence is categorized as "devastating," and it is noted, among other things, that children may suffer significant harm to their reputation, which can lead to social losses. The likelihood is categorized as "expected," and it is noted in this context that it is expected that there will be cases where a user mistakenly sends a message containing personal data to one or more users, for example, by sending to a group. However, Lolland Municipality does not appear to have addressed what KOMBIT's risk assessment material has specifically prompted Lolland Municipality to consider as the data controller. On this basis, the Data Protection Authority has asked Lolland Municipality to inform whether they have taken mitigating measures aimed at reducing the risk for the data subjects. If Lolland Municipality has not taken mitigating measures, the Data Protection Authority has requested Lolland Municipality to inform the authority of the reasons for this. Lolland Municipality has stated in their response that in 2022 it was decided that an updated impact and risk analysis should be conducted in collaboration with the individual schools for the AULA modules they use. In this context, Lolland Municipality has indicated that the new and updated risk and impact analyses do not change the fact that personal data processing continues to occur where there is a high risk to the rights and freedoms of the data subjects. Furthermore, Lolland Municipality has stated that the municipality has subsequently begun the task of identifying which mitigating actions can be established to reduce the risk to a acceptable level. At the time of the municipality's response on January 9, 2023, this work was still ongoing. Lolland Municipality has stated in this regard that the reason this work has not yet been completed is solely due to challenges in recruiting staff for two vacant positions in the area of information security.

It further appears from Lolland Municipality's response that three of the identified threats are not AULA-specific, but describe a general risk when managing roles and access to data. The following threats are involved:

1. Unintentional disclosure of personal data in the application, made by an authorized user.
2. Leakage of sensitive data due to incorrect (too low) or missing data classification.
3. Incorrect user or system access granted due to unclear access policies.

In this context, Lolland Municipality has stated that they are continuously conducting awareness campaigns aimed at both increasing the general understanding of information security and implementing a risk-consequence mindset among individual employees.

Finally, Lolland Municipality states that it is their impression that the current risk and consequence analyses depict a picture that is more risky than what practice actually is. This is based on observations that schools themselves have exhibited a risk-based approach in relation to the administration of AULA. As an example, it is mentioned in their statement that a school in the municipality has indicated that only their employees have access to "secure file sharing" in AULA, and that parents only have access to "secure file sharing" if they are assigned the role of board member.

In this context, Lolland Municipality states that this will be updated in connection with the work to identify which mitigating measures can be established to reduce the risk to an acceptable level.

3.2.2. Consequence Analysis

In relation to the Data Protection Authority's questions about consequence analyses regarding data protection, Lolland Municipality has referred to the 10 attached Excel sheets titled "Consequence Assessment" for 10 different modules in AULA, which have been prepared by KOMBIT. These Excel sheets are further described in the section above.

3.3. Reported Breaches of Personal Data Security Regarding AULA

The background for the Data Protection Authority's initial decision to supervise municipalities with a particular focus on the technical and organizational security measures observed to meet the requirement for an appropriate security level for processing in AULA is that the authority has seen (and continues to see) a number of reported breaches of personal data security in connection with the processing of personal data in AULA.

In AULA, personal data is processed, including confidential and sensitive personal data, about vulnerable registrants, which includes children. Furthermore, the system's users are often individuals

who do not primarily work with data protection (including educators, pedagogical staff, as well as students and parents), which, in the authority's view—given the many reported breaches from the vast majority of the country's municipalities—may imply that stricter requirements should be imposed on the data controllers' observance of both technical and organizational measures, cf. Article 32, as well as mitigating measures for compliance with Article 25 of the regulation.

A large portion of these reports of breaches of personal data security in AULA concern that personal data has been sent to one or more incorrect recipients in AULA. For example, where a message or secure file about a child has been sent to another child's parents, or where a message has been mistakenly sent to a group of recipients instead of a specific recipient. The Data Protection Authority has also seen cases where, when sending documents to one or more parents, an incorrect document containing information about another child has been attached. Thus, there have been several unintentional disclosures of personal data about children in AULA, including descriptions of children's concentration difficulties, recommendations for pedagogical-psychological assessment, information about dyslexia, school statements, as well as action plans and assessments of educational readiness.

By searching in the Data Protection Authority's ESDH system, the authority can ascertain that it has received four reports of breaches of personal data security from Lolland Municipality under Article 33 of the General Data Protection Regulation, where AULA is mentioned in the report. Three of the reports concern unauthorized access to personal data in AULA, including information about whether a contact person has parental authority over a child, profile pictures that have not had the necessary consent to display, and content in the module "secure file sharing." The last report concerns unintentional disclosure of personal data, where an employee mistakenly selects incorrect recipients for a message containing information about a child.

4. Justification for the Data Protection Authority's Decision

4.1. Risk Assessment

The General Data Protection Regulation requires, at several points, that a data controller addresses the risk to the rights and freedoms of the data subjects and can document the considerations and conclusions this has led to. It follows directly from the provisions in Articles 5, paragraph 1, letter f, 24, 25, 32, 33, 34, 35, 36, and 39, that the data controller addresses the risk to the rights and freedoms of the data subjects.

Furthermore, it follows from both Article 5, paragraph 2 regarding the principles in Article 5, paragraph 1, and Article 24 regarding compliance with the entire...

****Regulation****

A data controller must be able to demonstrate compliance with data protection regulations. Among other things, Articles 25, 35, and 36 require that considerations regarding the risks involved for the rights of the data subjects must take place before the processing activities are initiated. It follows from Article 5, paragraph 1, letter f of the Data Protection Regulation that personal data must be processed in a manner that ensures adequate security for the personal data in question, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures. The data controller must also be able to demonstrate that the fundamental principles are complied with, as follows from Article 5, paragraph 2 of the Data Protection Regulation. According to Article 32, paragraph 1 of the Data Protection Regulation, the data controller must take appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data. It follows from Article 24, paragraph 1 of the Data Protection Regulation that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in accordance with the regulation. The data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The data controller must also be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. In order for the supervisory authority to assess whether an appropriate level of security has been ensured, it must be

documented and explained which risks the data controller has identified and what mitigating measures have been taken to reduce these risks. To ensure an appropriate level of security, it is a prerequisite that the relevant security measures are implemented prior to the deployment of, for example, an IT solution where personal data is processed.

Following a review of Lolland Municipality's statements and the attached documents, the Data Protection Authority concludes that Lolland Municipality has adopted KOMBIT's risk assessments and, on that basis, identified the possible risks that the municipality's processing of personal data in AULA poses for the data subjects. The Data Protection Authority has noted that Lolland Municipality subsequently has the impression that the current risk assessments prepared by KOMBIT depict a picture that is more risky than what the actual practice is in the municipality. The Data Protection Authority has also noted what Lolland Municipality has stated regarding the decision made in October 2022 to conduct an updated impact and risk analysis in collaboration with the individual schools for the AULA modules used by the municipality. The Data Protection Authority understands that Lolland Municipality, despite the work on the updated risk and impact analyses, believes that personal data processing in AULA continues to occur where there is a high risk to the rights and freedoms of the data subjects.

The Data Protection Authority further concludes that Lolland Municipality – following the municipality's decision in October 2022 to conduct an updated impact and risk analysis – has begun the work of identifying what mitigating actions can be established to reduce the risk to an acceptable level. The Data Protection Authority understands that this work was not yet completed in January 2023, and that Lolland Municipality thus had not ensured at that time that appropriate security measures had been implemented to protect the data subjects from the identified risks. The Data Protection Authority finds on this basis that Lolland Municipality has not ensured that appropriate measures have been implemented to protect the data subjects from the identified risks. The Data Protection Authority therefore expresses serious criticism that Lolland Municipality's processing of personal data has not been carried out in accordance with Article 5, paragraph 1, letter f and Article 32, paragraph 1 of the Data Protection Regulation.

****4.2. Impact Analysis****

****4.2.1. Requirement for Impact Analysis****

As stated above in section 4.1, the Data Protection Authority understands from Lolland Municipality's statement that the municipality assesses that the processing of personal data in AULA is likely to involve a high risk to the rights and freedoms of natural persons. It follows from Article 35, paragraph 1, first sentence of the Data Protection Regulation that if a type of processing, particularly using new technologies and by its nature, scope, context, and purposes, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall carry out an analysis of the intended processing activities' consequences for the protection of personal data.

In the guidelines from the Article 29 Working Party (now the European Data Protection Board, EDPB) on impact analysis regarding data protection, criteria have been established that can help identify the processing activities that will require an impact analysis. It follows from the guidelines that a data controller in most cases can assume that a processing activity that meets two of the criteria must be subject to an impact analysis regarding data protection. The processing of personal data in AULA meets two of these criteria, as sensitive data is processed and...

confidential personal data about vulnerable registered individuals, including children. Furthermore, this concerns a system used for collaboration and communication between schools/daycare institutions and children and their parents. In the system, personal data is exchanged in messages, among other things, and there are many users associated with the system. The Data Protection Authority believes that this communication entails a risk that, due to human errors, personal data may inadvertently be disclosed to incorrect users. This is particularly relevant considering that the users consist of both municipal employees as well as children and their parents, and that – regardless of guidance – human errors will occur for which there are no immediate mitigating measures.

Generally, based on the types of information processed in AULA, the volume of information, the

number of transactions (exchange of information in connection with communication), and the diversity of users, there is not only a potential risk that the risk scenario will occur but also a real one.

The consequences for a registered individual's rights can, according to the Data Protection Authority, range across almost the entire scale of severity, from the less intrusive, such as receiving unintended messages, to more serious consequences such as significant reputational loss, to the extreme consequence where a registered individual's life is endangered by the disclosure of a concealed address, to mention just a few possible consequences.

The Data Protection Authority notes that any risk that entails a high consequence for the registered individuals' rights and freedoms – even with relatively low probabilities of the risk materializing – will likely involve a high risk for the registered individuals' rights, which triggers the obligation to conduct a data protection impact assessment, cf. Article 35, paragraph 1 of the regulation.

Furthermore, based on reports of breaches of personal data security concerning AULA, the Data Protection Authority has generally found that several of these would likely entail a high risk to the rights and freedoms of natural persons. Additionally, in several instances, the Authority has found that municipalities have deemed the conditions in Article 34 to be met and have notified the registered individuals about breaches of personal data security in AULA. The municipalities in question have thus assessed that the breaches likely pose a high risk to the rights and freedoms of natural persons.

Based on the above, the Data Protection Authority agrees with Lolland Municipality's assessment that the processing of personal data in AULA entails a high risk to the rights and freedoms of natural persons. The Data Protection Authority therefore finds that the processing activities carried out in AULA are subject to the requirement for a data protection impact assessment prior to the implementation of AULA.

4.2.2. Minimum requirements for impact assessments

Article 35 of the General Data Protection Regulation contains a number of requirements that a data protection impact assessment must meet at a minimum. These requirements follow from paragraph 7 and include the following:

1. a systematic description of the planned processing activities and the purposes of the processing, including, where applicable, the legitimate interests pursued by the data controller;
2. an assessment of whether the processing activities are necessary and proportionate to the purposes;
3. an assessment of the risks to the rights and freedoms of the registered individuals as referred to in paragraph 1; and
4. the measures envisaged to address these risks, including safeguards, security measures, and mechanisms that can ensure the protection of personal data and demonstrate compliance with this regulation, taking into account the rights and legitimate interests of the registered individuals and other affected persons.

The rules on data protection impact assessments in the General Data Protection Regulation are intended to ensure that no processing, where there is an inherent high risk to the rights and freedoms of the registered individuals, is initiated without the data controller having worked on and mitigated such risks.

A data protection impact assessment is thus a tool that enables the data controller to systematically address the risks that a processing activity may entail.

The Data Protection Authority has reviewed the 10 submitted Excel sheets titled "Impact Assessment" for 10 different modules in AULA, which were prepared by KOMBIT, as referred to by Lolland Municipality in response to the Authority's questions regarding the impact assessment. After reviewing the material, the Data Protection Authority finds that the documentation does not meet the minimum requirements for a data protection impact assessment, cf. Article 35, paragraph 7, letters a-d of the General Data Protection Regulation.

In this regard, the Data Protection Authority has emphasized that the documentation does not contain a systematic description of the processing activities in AULA, cf. paragraph 7, letter a of the provision. Instead, the documentation only provides a general indication of the purpose of the processing activities in the various modules of AULA.

Furthermore, the Data Protection Authority has emphasized that the documentation does not include an assessment of whether the processing activities are necessary and proportionate to the purposes, cf. paragraph 7, letter b of the provision.

Finally, the Data Protection Authority has emphasized that the documentation does not contain an assessment of the measures that can be implemented to address the risks identified in the material.

****Ref. provision's section 7, letter d.****

On this basis, the Danish Data Protection Agency's overall assessment is that Lolland Municipality has not conducted a sufficient impact assessment, cf. Article 35, section 1 of the General Data Protection Regulation, as the submitted documentation does not meet the minimum requirements set out in Article 35, section 7 of the Regulation.

In this context, the Data Protection Agency assesses that the submitted material does not constitute an impact assessment, and that Lolland Municipality has therefore not prepared an impact assessment for the processing of personal data in AULA. The Data Protection Agency has placed particular emphasis on the fact that Lolland Municipality does not appear to have worked with or attempted to mitigate the risks associated with the processing of personal data in AULA in the submitted material. It is the Data Protection Agency's opinion that an impact assessment should particularly include the measures, guarantees, and mechanisms planned to limit the identified risks, to ensure the protection of personal data, and to demonstrate compliance with the General Data Protection Regulation.

****4.2.3. Requirement to consult the data protection officer****

It follows from Article 35, section 2 of the General Data Protection Regulation that the data controller must consult the data protection officer, if one has been appointed, when conducting an impact assessment regarding data protection. Furthermore, it follows from Article 39, section 1, letter c of the Regulation that the data protection officer must, at a minimum, provide advice when requested regarding the impact assessment related to data protection and monitor its compliance in accordance with Article 35.

It does not appear from the submitted documentation whether, and if so to what extent, Lolland Municipality's data protection officer has had comments on the prepared documentation.

The Data Protection Agency recommends that Lolland Municipality includes any contributions from the municipality's data protection officer in future impact assessments. The comments from the data protection officer regarding the advice that is required under Article 35, section 2 of the General Data Protection Regulation are of significant importance for documenting that the data protection officer has had the opportunity and space to perform the tasks assigned to them under Article 39 of the General Data Protection Regulation. In this context, the Data Protection Agency notes that the data controller must ensure that the data protection officer is involved sufficiently and in a timely manner, cf. Article 38, section 1 of the General Data Protection Regulation.

****4.2.4. Timing of the preparation of the impact assessment****

It follows from Article 35, section 1 of the General Data Protection Regulation that an impact assessment regarding data protection must be conducted prior to the processing.

The Data Protection Agency has noted during a supervisory visit to KOMBIT in December 2019 that there has been uncertainty regarding where the data responsibility for the processing of personal data in the solution is placed in connection with the development of AULA. Both the municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thus also the responsibility for conducting risk assessments and impact assessments – was placed with KOMBIT.

As mentioned above under point 1, the Data Protection Agency has established during the relevant supervisory visit to KOMBIT that KOMBIT is not to be regarded as the data controller, and therefore the Agency informed KOMBIT that it must ensure that all municipalities are informed of their data

responsibility, and that KOMBIT must transfer all necessary material and information to the municipalities in this regard.

The Data Protection Agency assumes that this uncertainty regarding data responsibility has been a reason why Lolland Municipality has not prepared an impact assessment prior to their processing of personal data in AULA. In this context, the Data Protection Agency assumes that Lolland Municipality, upon the implementation of AULA, believed that KOMBIT was the data controller for the processing of personal data in the solution and thus also responsible for preparing a risk assessment and impact assessment.

Based on the Data Protection Agency's supervisory visit to KOMBIT in December 2019 and the submitted material from KOMBIT in this regard, the Data Protection Agency assumes that KOMBIT, in connection with the development of AULA – and before it was established that the municipalities were the data controllers – conducted assessments of the risks and consequences for the data subjects regarding the processing of personal data in AULA, which show that the processing involves a high risk for the data subjects.

Thus, it is the Data Protection Agency's opinion that Lolland Municipality – like the other municipalities – should have recognized the high risk associated with the processing of personal data in AULA in connection with KOMBIT informing the municipalities of their data responsibility regarding the processing of personal data in AULA and transferring all necessary material in this regard.

The Data Protection Agency assumes that KOMBIT informed the municipalities about this shortly after the supervisory visit in December 2019.

However, the Data Protection Agency can establish that Lolland Municipality only decided in October 2022 that an updated impact and risk analysis should be conducted, and that the work had not yet been completed in January 2023. As mentioned above under point 4.2.2, the Data Protection Agency has further assessed that the submitted material, which the municipality has referred to regarding the issue of the impact assessment, does not constitute an impact assessment.

It is the Data Protection Agency's opinion that Lolland Municipality should have recognized the municipality's data responsibility for the processing of personal data in AULA as well as the... high risk that the processing entails, should have initiated the preparation of a impact assessment. The Data Protection Agency has particularly taken into account in its assessment that the purpose of an impact assessment is to determine the specific risks associated with the processing for the rights and freedoms of the data subjects and subsequently ensure that – before the processing begins – measures are established to mitigate these risks and reduce the risk to a level that is less than high.

4.2.5. Overall assessment regarding the impact assessment

After reviewing the submitted material, which Lolland Municipality has referred to in relation to the Agency's questions about the impact assessment, the Data Protection Agency finds that Lolland Municipality has not conducted a comprehensive impact assessment, cf. Article 35, paragraph 1 of the General Data Protection Regulation, as the submitted documentation does not meet the minimum requirements set out in Article 35, paragraph 7 of the Regulation.

In this context, it is the Data Protection Agency's assessment that the submitted material does not constitute an impact assessment, and that Lolland Municipality has therefore not prepared an impact assessment for the processing of personal data in AULA.

The Data Protection Agency has placed particular emphasis on the fact that Lolland Municipality does not appear to have worked with and attempted to reduce the risks associated with the processing of personal data in AULA in the submitted material. It is the Data Protection Agency's opinion that an impact assessment should particularly include the measures, guarantees, and mechanisms that are planned to limit the identified risks, to ensure the protection of personal data, and to demonstrate compliance with the General Data Protection Regulation.

On this basis, the Data Protection Agency finds grounds to express serious criticism that Lolland Municipality's processing of personal data has not occurred in accordance with Article 35, paragraph 1. The Data Protection Agency finds, on this basis, grounds to issue Lolland Municipality an order to conduct an impact assessment regarding data protection for the municipality's processing of personal data in AULA in accordance with Article 35 of the General Data Protection Regulation. The order is

issued pursuant to Article 58, paragraph 2, letter d of the General Data Protection Regulation.

The deadline for compliance with the order is March 22, 2024.

As noted above under point 4.1, the Data Protection Agency has taken note that Lolland Municipality decided in October 2022 that an updated impact and risk assessment should be conducted.

In choosing a response, the Data Protection Agency has emphasized that Lolland Municipality had not yet prepared an impact assessment for the processing of personal data in AULA as of January 2023, when the Agency received the municipality's latest statement, despite the fact that shortly after the Data Protection Agency's inspection visit to KOMBIT in December 2019, the municipality was made aware that it is the data controller for the processing of personal data in a solution that entails a high risk for the data subjects.

4.3. Summary

On the basis of the above, the Data Protection Agency finds grounds to express serious criticism that Lolland Municipality's processing of personal data has not occurred in accordance with the rules in Article 5, paragraph 1, letter f, and Article 32, paragraph 1 of the General Data Protection Regulation. Furthermore, the Data Protection Agency finds grounds to express serious criticism that Lolland Municipality's processing of personal data has not occurred in accordance with Article 35, paragraph 1 of the Regulation.

The Data Protection Agency finds, on this basis, grounds to issue Lolland Municipality an order to conduct an impact assessment regarding data protection for the municipality's processing of personal data in AULA in accordance with Article 35 of the General Data Protection Regulation. The order is issued pursuant to Article 58, paragraph 2, letter d of the General Data Protection Regulation.

The deadline for compliance with the order is March 22, 2024.

4.4. General remarks from the Data Protection Agency

In system landscapes where multiple data controllers use the same systems and perform approximately the same processing of personal data, there can be significant synergy in conducting joint assessments regarding risk factors, potential impact assessments, and mitigating measures.

The Data Protection Agency notes that it may be relevant to conduct a joint impact assessment if several data controllers plan to implement a common IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that it concerns the same type of system, the same processing activity of the same personal data, and that the processing activities entail similar high risks.

It is not crucial that there is full identity between the systems and processing activities, but that the system, data, and particularly the processing activities do not deviate significantly from each other. Otherwise, a supplement to the joint impact assessment must necessarily be prepared.

Thus, it is the Data Protection Agency's opinion that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are performed in the system, processing the same types of data.

personal data, and the processing activities involve the same high risks.

It is the data controllers who specifically assess whether a joint

impact assessment can be conducted for the processing activities in the systems. The data controllers in a joint impact assessment are each responsible for conducting the impact assessment.[9]

It is the opinion of the Data Protection Agency that, in relation to the municipalities' processing of personal data in AULA, it is noted that the municipalities use the same type of system for the same processing activities of the same types of personal data, and that the municipalities' processing activities involve similar high

risks. Furthermore, the system is provided by the same supplier. Thus, the municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA.

In associations and bodies that represent categories of data controllers, it can also be beneficial to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation to specify the application of the General Data Protection Regulation.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to assist in complying with data protection rules for the authorities that have subscribed to the code.

This facilitates compliance with the rules but does not relieve the individual data controller of the duties and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions

in the joint concepts and processing, for example, by using a system for other purposes.

On this basis, the Data Protection Agency encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with

Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA.

This may also be relevant to consider in relation to other processing activities in the municipalities, where the municipalities use the same system for processing the same types of personal data for the same purposes.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Act No. 502 of 23 May 2018 on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data (Data Protection Act).

[3] KL has described the User Portal Initiative on their website: <https://www.kl.dk/kommunale-opgaver/boern-og-unge/digitalisering-paa-boerne-og-ungeomraadet/brugerportalsinitiativet/>

[4] KOMBIT provides information about AULA on the website <https://aulainfo.dk/om-aula/>

[5] It appears from materials about the User Portal Initiative, which are available on KL's website: <https://www.kl.dk/media/11560/illustration-af-aftaler-om-databehandling-i-og-omkring-bpi.pdf>

[6] Guidelines for Data Protection Impact Assessment (DPIA) and determining whether the processing "likely results in a high risk" under Regulation (EU) 2016/679, WP248 rev. 01, adopted on 4 April 2017, as last revised and adopted on 4 October 2017.

[7] Reference is made to recital 90 of the General Data Protection Regulation.

[8] Reference is made to recital 90 of the General Data Protection Regulation.

[9] Reference is made to the Data Protection Agency's guidance on impact assessment from March 2018.